



AI Governance Guide for Regulated Organizations

A practical framework for governing AI tools under SEC, FINRA, and HIPAA requirements.

Regulatory Landscape for AI

The regulatory environment for AI in financial services and healthcare is evolving rapidly. Key frameworks include:

- SEC Investment Advisers Act §206: AI-driven recommendations may constitute investment advice subject to fiduciary duty.
- Proposed Rule on Predictive Data Analytics (2023): Requires evaluation and neutralization of conflicts of interest in AI/predictive models.
- FINRA Rule 3110 (Supervision): Firms must supervise AI-generated communications with the same rigor as human-produced content.
- HIPAA Privacy Rule: AI systems processing PHI must meet minimum necessary standards.
- NIST AI Risk Management Framework: Voluntary but increasingly referenced by regulators as a governance baseline.

AI Governance Framework

An effective AI governance program should address:

- ✓ AI Inventory & Classification: Catalog all AI tools in use, classify by risk tier (high, medium, low).
- ✓ Approval Workflow: Require security, legal, and compliance sign-off before deployment.
- ✓ Data Governance: Define what data AI tools can access, process, and retain.
- ✓ Bias & Fairness Testing: Implement pre-deployment and ongoing bias audits.
- ✓ Model Explainability: Ensure AI decisions can be explained to regulators and clients.
- ✓ Incident Response: Establish procedures for AI-related incidents and errors.

Risk Assessment Methodology

Each AI system should be evaluated across five risk domains:

- Data Risk: What data does the AI access? Is it client PII, PHI, or material nonpublic information?
- Model Risk: Can the model produce biased, inaccurate, or unexplainable outputs?
- Operational Risk: What happens if the AI fails? Is there a manual fallback?
- Regulatory Risk: Does the AI's use trigger specific regulatory requirements?
- Reputational Risk: Could the AI's outputs damage client trust or public perception?

Implementation Checklist

- Appoint an AI Governance Officer or Committee
- Create an AI Tool Inventory with risk classifications
- Develop an AI Acceptable Use Policy
- Implement pre-deployment approval workflows
- Establish ongoing monitoring and audit schedules
- Train staff on AI governance policies and procedures
- Document AI-related incidents and remediation actions
- Review and update AI governance program quarterly

Ongoing Monitoring & Compliance

AI governance is not a one-time exercise. Organizations must:

- Conduct quarterly reviews of AI tool inventory and risk classifications.
- Monitor regulatory developments and update policies accordingly.
- Perform annual bias and fairness audits on high-risk AI systems.
- Maintain detailed logs of AI system inputs, outputs, and decisions.
- Report AI-related incidents to compliance within 24 hours.
- Engage external auditors annually to validate AI governance controls.